

Can machine learning reveal what severity scores miss?

I analyzed 346,232 vulnerabilities to discover distinct risk profiles — then enriched them with threat intelligence.

VULNIQ

346,232 CVEs

15 features • 3 clustering approaches • 4 profiles

A vulnerability-profiling workflow using K-Means, Agglomerative Clustering and DBSCAN.

Swipe →

Not all vulnerabilities with similar severity carry the same risk.

Traditional vulnerability management relies heavily on CVSS severity. But vulnerabilities can differ significantly in:

Exploitation likelihood EPSS can separate vulnerabilities with very different likelihood of exploitation.

Known exploitation CISA KEV adds evidence that a vulnerability is being exploited in the wild.

Attack characteristics Vector, complexity, privileges and user interaction change the exposure profile.

Impact & age Impact and vulnerability age add context that severity alone does not capture.

Question: Can ML uncover vulnerability populations that warrant different remediation strategies?

An end-to-end vulnerability profiling workflow.

01

346,232 CVEs

Starting vulnerability population

02

15 risk & attack features

Severity • exploitability • EPSS • KEV • attack • CIA • age

03

Encoding + standardization

Prepared a comparable ML-ready feature space

04

Unsupervised clustering

K-Means • Agglomerative • DBSCAN

05

Threat intelligence enrichment

CWE • Vendor • Product

06

Actionable profiles

Translate statistical groups into remediation insight

I tested three clustering approaches — not just one.

K-MEANS

Full 346K dataset

K=4 selected

Scalable, differentiated and interpretable profiles.

AGGLOMERATIVE

20K sample

Best silhouette: 0.3476 at K=2

Useful validation, but broader segmentation.

DBSCAN

20K sample

Final eps: 2.25

Highly imbalanced; ~79% concentrated in one cluster.

FINAL CHOICE • K-MEANS K=4

Selected for the practical balance of scalability, differentiation and business interpretability.

A tiny vulnerability segment contained most known exploited vulnerabilities.

JUST

1.76%

OF THE CVEs

↓ ACCOUNTED FOR ↓

58.08%

OF ALL CISA KEVs IN THE DATASET

Severity or vulnerability volume alone can hide concentrated exploitation risk.

The model separated the backlog into four very different populations.

0 EXPLOITATION HOTSPOT

1.76% of CVEs • 58.08% of KEVs

Extreme EPSS signal + higher severity/impact.

→ Immediate investigation / remediation

1 HIGH SEVERITY & IMPACT

30.94% of CVEs • 33.15% of KEVs

Higher severity and impact; lower exploitation signal than Cluster 0.

→ High-priority risk-based remediation

2 OLDER & HIGHLY EXPLOITABLE

20.17% of CVEs • 0 KEVs in this dataset

Highest relative exploitability and vulnerability age.

→ Target legacy / exposure backlog

3 LARGE LOWER-SIGNAL POPULATION

47.13% of CVEs • 8.77% of KEVs

Largest group; comparatively lower severity, impact and exploitation indicators.

→ Planned risk-based remediation

Clustering tells us which CVEs behave similarly. Threat intelligence tells us what they are.

CWE

Weakness

Which weakness patterns dominate?

VENDOR

Technology

Which vendors are concentrated?

PRODUCT

Exposure

Which products drive the population?

EXAMPLES FROM THE FOUR PROFILES

Cluster 0

CWE-119 • CWE-22 •
CWE-78

Microsoft • Apache • Adobe IE • Windows • HTTP Server

Cluster 1

CWE-787 • CWE-89 •
CWE-416

Google • Microsoft • Linux Android • Linux Kernel • Chrome

Cluster 2

CWE-79 • CWE-119 •
CWE-89

Microsoft • Oracle • Apple macOS • Linux Kernel • Firefox

Cluster 3

CWE-79 • CWE-200 •
CWE-862

Linux • Google • IBM

Linux Kernel • Android • Chrome

Profile → weakness + vendor + product → targeted remediation campaign

Severity tells part of the story. Exploitability + threat intelligence + ML reveal much more.

VULNIQ transforms a large vulnerability backlog into interpretable profiles that can support targeted, threat-informed remediation decisions.

WHAT I LEARNED

01

Model quality is not only one metric.

Silhouette score matters, but scalability and interpretability matter too.

02

Enrichment changes the business value.

Clusters become more useful when connected to CWE, vendor and product context.

03

The strongest insight was concentration.

1.76% of CVEs contained 58.08% of all CISA KEVs in the dataset.

VULNIQ • Machine Learning-Based Vulnerability Profiling & Threat Intelligence